

DAY 22 ASSIGNMENT

Name:- Rishabh Raj

1. What is authentication?

Authentication is the process of verifying the identity of a user or system. It answers the question, "Who are you?" and may use passwords, OTPs, biometrics, or security keys.

2. What is authorization?

Authorization is the process of deciding what an authenticated user is permitted to access or perform. It answers the question, "What are you allowed to do?"

3. Explain the difference between authentication and authorization.

Authentication verifies identity, while authorization determines permissions. For example, logging in with a password is authentication; being allowed to access the admin panel is authorization.

4. What is access control?

Access control is a security mechanism that determines which users or systems can access particular resources and what actions they can perform on those resources.

5. What is Broken Access Control?

Broken Access Control is a security weakness in which an application fails to properly enforce authorization rules. Attackers may then access, modify, or delete resources or perform actions outside their intended permissions.

6. What does Least Privilege mean?

Least Privilege means giving a user, application, or process only the minimum permissions needed to perform its required task, and no unnecessary privileges.

7. What does Deny by Default mean?

Deny by Default means access should be refused unless a user or request is explicitly granted permission. This reduces accidental or unauthorized access.

8. Why is authentication alone not enough to protect sensitive functionality?

Authentication only proves who the user is; it does not prove that the user is authorized for a particular action. A normal authenticated user could otherwise access administrative functions if authorization checks are missing.

9. Explain vertical access control.

Vertical access control restricts functionality according to a user's privilege level or role. For example, an administrator may manage users while a normal student cannot.

10. Give one fictional example of a vertical access control problem.

Suppose a student logs in normally but can directly access `/admin/delete-user` and delete another account because the server checks only that the user is logged in. This is a vertical access control failure.

11. Explain horizontal access control.

Horizontal access control restricts users from accessing resources belonging to other users who have the same privilege level. Each user should normally access only the resources they are entitled to.

12. Give one fictional example of a horizontal access control problem.

Suppose Student A can change the profile of Student B simply by changing the user ID in a request. Both students have the same role, but Student A should not access Student B's private data.

13. What is context-dependent access control?

Context-dependent access control makes authorization decisions based on additional conditions or context, such as time, location, device, transaction status, or the current state of a workflow.

14. Give one simple fictional example.

A company portal may allow an employee to approve a payment only during an authorized workflow and only from a managed company device. Even if the employee is authenticated, the action is denied when those conditions are not satisfied.

15. What is an object/resource identifier?

An object or resource identifier is a value used by an application to identify a particular resource, such as a user ID, order number, document ID, invoice ID, or record ID.

16. Explain the IDOR concept in your own words.

IDOR (Insecure Direct Object Reference) occurs when an application exposes a resource identifier and fails to verify whether the requesting user is authorized to access that specific resource. Changing an identifier may therefore expose another user's data.

17. Why does knowing a record ID not automatically mean a user is allowed to access it?

A record ID only identifies a resource; it does not establish ownership or permission. The server must independently verify that the authenticated user has permission to access that particular record.

18. Why must ownership/permission be checked on the server?

Client-side checks can be modified or bypassed by an attacker. Server-side authorization checks are performed in trusted application logic and therefore provide the actual security boundary before sensitive operations are completed.

19. Why is hiding an Admin button in the browser not enough security?

Hiding a button only changes the user interface; it does not prevent a user from manually sending a request to the administrative endpoint. The server must enforce authorization for every protected action.

20. Explain why authorization checks should be performed in trusted server-side logic.

The server controls access to protected resources and cannot rely on client-side code because clients are under the user's control. Server-side checks ensure that every request is validated against the user's role, ownership, and permissions before the action is performed.